

AI Shop Vision Agent API — developer guide

What you can build

Use this API to add shelf analysis to a web, mobile or command-line application. The client submits one photograph or video, observes server-owned progress, and retrieves a report of identified products, visible facing counts and uncertainty. The client does not need an OpenAI credential or its own video-frame extraction code.

This guide covers the Vision Agent and Admin APIs, plus health and Storage transfer. The separate reviewer [/inspections](#), legacy analysis and VISTA package-ingestion interfaces are outside this guide; do not treat them as interchangeable upload routes.

Environment: **TEST**, Firebase project [aishop-99d36](#); not a production declaration. Written against the repository endpoint guides and the September 15, 2026 manual tests. Examples of untested routes describe contracts, not live acceptance.

Architecture in one minute

The API is the application's front door. Firebase authenticates the caller; Firestore holds the durable analysis record; Cloud Storage holds evidence. For video, Cloud Tasks dispatches a worker that uses FFmpeg to select frames. The server starts background model analysis and collects its eventual result. The browser or mobile app only observes the saved state and renders the report.

```
Client — reserve —> API —> durable analysis record
Client — video bytes —> Cloud Storage
Client — complete —> API —> video worker —> background AI
Client <— GET status/report — API <— durable result settlement
```

Refreshing the client does not cancel accepted background analysis. Refreshing during byte transfer is different: an incomplete upload still needs its remaining bytes, and the browser may need the user to select the file again. Do not confuse a fast [processing](#) acknowledgment with finished analysis. See [architecture](#) and [implementation details](#).

Connect and authenticate

Direct base, used for our curl isolation tests:

```
https://northamerica-northeast2-aishop-99d36.cloudfunctions.net/api
```

The hosted [/v1](#) routes also use [https://aishop-99d36.web.app](#) through rewrites. Use the direct base while diagnosing backend failures independently of Hosting.

Every Agent request needs **Authorization: Bearer <Firebase ID token>** and the literal custom claim **agent: true**. Admin requests separately require **admin: true**. Creating a Firebase account is

not sufficient to grant either application role. These roles are not Google Cloud IAM administrator privileges. The Agent API derives ownership from the verified user; callers cannot choose an owner.

Sign in through Firebase in your app. For our password-account curl tests, use the saved sign-in script below; never use a Google account password as a substitute for a Firebase password credential. Never embed an administrator credential in a client. After claims change, obtain a new ID token: existing tokens do not change in place.

Reproduce the verified path with small scripts

From the repository root, start **bash**. Run **one line at a time**, inspecting the output before advancing. Source the scripts so TOKEN and upload variables remain in the same shell. Requires curl, jq, Node; file-size commands target macOS. Do not enable shell tracing. No password or token should enter the evidence documents.

Step	Command after entering Bash	Expected result
Health	<code>source scripts/agent-api-tests/001-health.sh</code>	200, status ok
No credential	<code>source scripts/agent-api-tests/002-missing-auth.sh</code>	401
Invalid credential	<code>source scripts/agent-api-tests/003-invalid-token.sh</code>	401
Password sign-in	<code>source scripts/agent-api-tests/004-sign-in.sh</code>	signedIn true
My analyses	<code>source scripts/agent-api-tests/005-authorized-list.sh</code>	200, array
Token flags	<code>source scripts/agent-api-tests/006-token-roles.sh</code>	role booleans
Admin list	<code>source scripts/agent-api-tests/010-admin-list.sh</code>	200 if Admin
Reserve video	<code>source scripts/agent-api-tests/011-reserve-video.sh</code>	201, uploading
Transfer bytes	<code>source scripts/agent-api-tests/012-transfer-video.sh</code>	200 or 201
Inspect transfer	<code>source scripts/agent-api-tests/013-inspect-upload-session.sh</code>	200/201 complete; 308 incomplete
Start processing	<code>source scripts/agent-api-tests/014-complete-video.sh</code>	200, normally processing
Read status	<code>source scripts/agent-api-tests/015-video-status.sh</code>	eventually analyzed or failed

Step	Command after entering Bash	Expected result
Read report	<code>source scripts/agent-api-tests/016-read-report.sh</code>	analyzed with report
Compare original	<code>source scripts/agent-api-tests/017-verify-original.sh</code>	intended: 200, identical true; currently failed live

Run status reads no more frequently than every 15 seconds and stop on a terminal state. Completion, run and restart can incur AI charges. Status reads do not start work. Our tests are individual requests, not an unattended retry loop. See the [script instructions](#) and [test/result collection](#).

Endpoint reference

Paths below are relative to the direct base. `id` is the returned analysis ID. Keep it: it connects upload, processing, report, evidence and diagnostics.

Health

GET /health — public liveness check. Returns `200 {"status":"ok"}`. It does not prove Storage, authentication, worker delivery or AI availability.

Video creation and transfer

POST /v1/agent/video-uploads — reserve a new video. Supply Agent authentication, `Origin: https://aishop-99d36.web.app`, JSON content type and this request shape:

```
{"fileName":"shelf.mov","mediaType":"video/quicktime","byteLength":123456}
```

Use the actual byte length, not this illustrative value. MP4 uses `video/mp4`. Success is 201 with `analysis` and `upload.uri`. Retain the URI privately in memory. Reservation sends no video bytes and is not a client-idempotent create operation. On an uncertain POST result, inspect the list before creating another record.

PUT <upload.uri> — send bytes directly to Storage, not to the API base. This is a capability URL: do not log/share it or attach the Firebase token. For one full-file PUT, send the media Content-Type and `Content-Range: bytes 0-(size-1)/size`, with the actual inclusive end and total. Use the saved transfer script to form these values correctly. Do not follow 308 as a redirect; it means an incomplete resumable transfer. An empty PUT with `Content-Range: bytes */size` queries status. Trust the returned Range exactly; absent Range on 308 means no bytes acknowledged. The whole-file curl test does not validate interruption/resume or browser CORS. See [reservation](#) and [chunked transfer recipes](#).

POST /v1/agent/video-uploads/{id}/session — renew an uploading record's session. Requires Origin and Agent authentication; returns 201 with the replacement URI. Do not assume previously transferred bytes survive. Leaving uploading normally yields 409.

POST /v1/agent/video-uploads/{id}/complete — after Storage confirms completion, verify the stored source and request background processing. No JSON body is required. Returns 200 with

analysis, normally in processing. This is not a final report.

JPEG creation and analysis runs

POST /v1/agent/analyses — multipart form with exactly one JPEG field named **file**. Let curl generate its multipart boundary: `-F "file=@$IMAGE;type=image/jpeg"`. Returns 201 with an uploaded record. Optional form field **run=true** starts analysis. Do not assume initiation failure means the successfully uploaded record disappeared.

POST /v1/agent/analyses/{id}/run — initiate an eligible run or refinement. An initial photograph run needs no context; refining an analyzed photograph requires a meaningful JSON note such as `{"context":"Focus on visible front-facing products."}`. Returns 200 with the current analysis, not necessarily the final result. Active work conflicts with another run. Video retry/refinement through this route is a review gap, not part of the verified video happy path. See [JPEG and run curl recipes](#).

Agent reads

GET /v1/agent/analyses — returns `{"analyses":[...]}` for the authenticated owner. An empty array is valid. This is not the cross-user Admin list or its pagination contract.

GET /v1/agent/analyses/{id} — returns `{"analysis":{...}}`, including current status and report when available. Use this to restore the UI after a page refresh. The client should handle processing, uploaded, analyzing, analyzed, failed and cancelled, as well as uploading before completion. Preserve the existing ID rather than recreate work.

GET /v1/agent/analyses/{id}/source — intended to return original binary evidence. Download into a new file, never over the local source, and check HTTP before hashing it. **Known live failure:** our video test returned 500 with an empty body. Do not yet claim this endpoint or video playback is working. Range serving is not implemented. Missing or unowned record IDs should return 404 without exposing another user's evidence. See [completion/read recipes](#).

Cancellation and restart

POST /v1/agent/analyses/{id}/cancel — cancel an eligible active record. Fetch the current detail first and send `{"version":CURRENT_VERSION}`. Inspect **outcome** and **analysis**, not HTTP 200 alone: a saved completion can win, a stale version can report changed, and an already-cancelled record is not new work. Cancellation is not evidence deletion; running external work may still incur charges.

POST /v1/agent/analyses/{id}/restart — restart an eligible cancelled video with complete source evidence. Fetch its latest version and send the same JSON shape. Current implementation re-enters processing with a new attempt and re-extracts frames. It is not a way to repair an upload whose bytes never arrived. Late work from an old attempt must not overwrite the new attempt's state. Use disposable records for these tests. See [recovery curl recipes](#). There is no standalone **/fresh** endpoint; a fresh start is client orchestration.

Admin reads

GET /v1/admin/analyses — Admin-only cross-user list, returning analyses and nextCursor. Filters: owner, status, from, to, cursor and limit. Owner is the returned owner key, not an email. Dates use YYYY-

MM-DD UTC. Default page size 25, maximum 50. Keep filters unchanged when following nextCursor; page count is not total record count.

`GET /v1/admin/analyses/{ownerKey}/{id}` — Admin-only detail with an owner label. Obtain both identifiers from the list rather than inventing or mixing them.

`GET /v1/admin/analyses/{ownerKey}/{id}/source` — Admin-only original binary evidence. This route has not been proven by the successful Admin list test. See [Admin curl recipes](#) for filters, pagination and negative tests. No role-management write API or Admin bulk-cancellation API is implemented here. Role grants currently use the individual [admin scripts](#).

Errors, evidence and safe testing

Normal API errors use `{"error": {"code": "...", "message": "...", "retryable": false, "requestId": "..."} }`. 401 means authentication rejection; 403 means insufficient application authorization. 400/415/413 may indicate malformed input, unsupported media or a size violation. 409 indicates a state conflict. Capture request ID, analysis ID, status and safe message. Do not assume every failure has a JSON body: the source-download 500 had none. Storage errors use a different response format; capture both reason and sanitized message. Do not retry POSTs blindly, weaken bucket security, or expose session URLs in logs.

Our ACL failure was caused by passing `private: true` when creating the Storage session. Uniform bucket-level access rejects legacy ACL operations. Removing that option fixed the demonstrated fresh-session transfer without changing bucket access permissions. Old failed sessions are not proof that the corrected session code still fails.

The verified video reached analyzed with a report; the browser also rendered a report. This establishes a working path for that test input, not universal media compatibility. Counts and product names remain model claims until checked against the visual evidence. One report explicitly warned that a counted item might instead be signage.

See [limits and review gaps](#) before integrating retries, large media or recovery, and [diagnostics](#) before changing behavior. Private worker functions are IAM-controlled implementation details: invoke them through the public workflow, not by making them public for curl tests.